



Lab 6 — Draft the AI Acceptable Use and Governance Policy Set

Topic 02: Building an AI Governance Framework: Policies, Roles and Risk Ownership

Objective: Evaluate policy requirements and develop an enforceable AI policy set aligned to the NIST AI RMF and Singapore's MGF for Generative AI.

Goal: Policy is where governance becomes enforceable. You will draft NovaBank's AI Acceptable Use Policy and the supporting standard, working from the gap register you produced in Lab 5 and the nine dimensions of Singapore's Model AI Governance Framework for Generative AI.

What you'll build: A complete AI Acceptable Use Policy (2 pages) plus a one-page AI Risk Management Standard, both mapped to MGF dimensions and RMF subcategories.

Tools and data: Policy templates (aup-template.md, standard-template.md), MGF nine dimensions reference, Lab 5 gap register

Data files in this lab

- data/aup-template.md
- data/mgf-nine-dimensions.md
- data/standard-template.md

Step-by-step

1. Open aup-template.md in labs/lab-06-policy-set/data/ and review the required sections: purpose, scope, definitions, permitted use, prohibited use, approval, roles, monitoring, breach and review.
2. Define scope precisely. State whether the policy covers public GenAI tools, embedded AI features in existing SaaS, internally built models and third-party agents — vague scope is the most common policy defect.
3. Write the permitted-use section. Specify what staff may do with approved AI tools, with which data classifications, and under what logging.
4. Write the prohibited-use section with concrete rules: no confidential or personal customer data into unapproved tools; no AI-generated code merged without human review; no automated decision about a customer without a documented human check.
5. Write the approval pathway. State who approves a new AI system, what evidence they need, and the maximum turnaround — a pathway with no service level is a pathway staff will bypass.

6. Map every clause to the MGF dimension it serves — accountability, data, trusted development and deployment, incident reporting, testing and assurance, security, content provenance — and record the mapping in a table.
7. Draft the one-page AI Risk Management Standard: risk tiering criteria, the assessment required at each tier, who signs off, and the review frequency.
8. Add the enforcement and consequence section, and the review cycle with a named owner and a date. A policy with no owner and no review date is already obsolete.
9. Peer-review another group's policy against one test: could a member of staff read this and know exactly what they may and may not do on Monday morning? Record two specific improvements.

Test it

Your AUP states at least six concrete prohibited actions, names the approver and the turnaround time, and every clause maps to at least one MGF dimension. A peer confirms they could apply your policy without asking you a question.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.